

① **MAPA CON CITAS LEGALES:** Conexiones respaldadas por artículos de ley. Grosor de las líneas = requisitos legales satisfechos. Datos de costos: FideliNorm 2026. Brecha de datos: USD 4.2M IBM/G-CERTI. Multas: Ley 21.663 Art.40.

METRICA CLAVE

Por cada USD 1 invertido en ciberseguridad en LATAM, el costo esperado de una brecha es **USD 49.** — TTPSEC / G-CERTI 2026

(IBM: Costo de una Brecha de Datos 2025)

62%

Reduccion de impacto con ISO 27001
De USD 4.2M a USD 1.6M (G-CERTI)

8.3

Meses para recuperar inversion ISO 27001
ROI promedio en LATAM (G-CERTI 2026)

40.000

UTM de techo legal maximo Ley 21.663
Infraccion gravisma OIV Art.40 (sancion
discrecional)

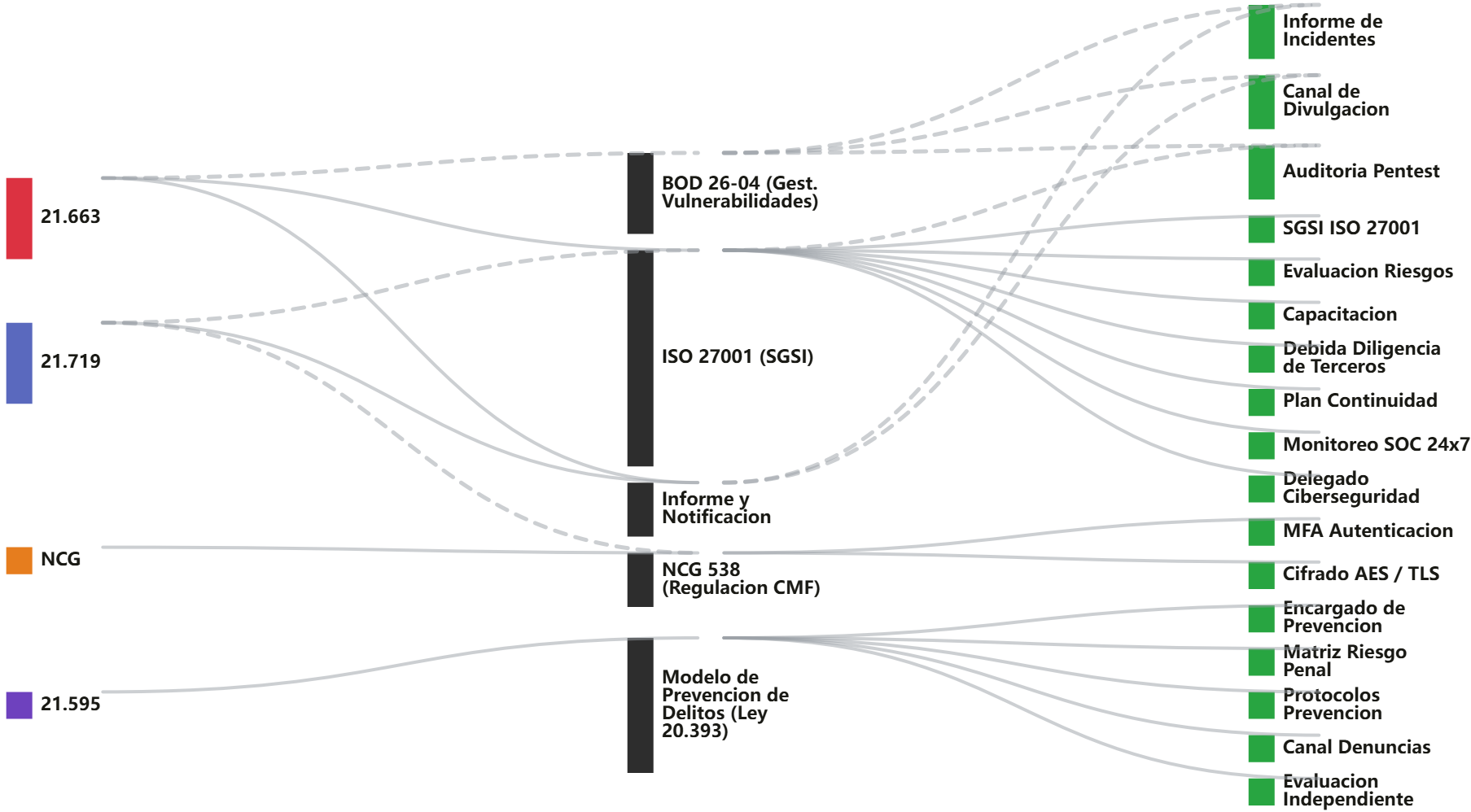
20.000

UTM de techo legal maximo Ley 21.719
Infraccion gravisma APDP. Vigente 1-Dic-2026

Mapa de Convergencia Regulatoria con Citas Legales

Jerarquía de 3 capas: **Leyes** (izquierda) exigen **estándares** (centro), que se rellenan con **controles** (derecha). En reposo todo se muestra en **gris neutro** (sólido = obligatorio/exclusivo · punteado = referencia/transversal) para una lectura calmada. Al pasar el **cursor** aparecen los colores: **rojo = obligatorio** (ley exige el estándar y sus controles) · **azul = satisface (referencia)**. Los controles se implementan, los estándares se completan y las leyes se satisfacen. Un recuadro emergente muestra la relación exacta.

LEYES 21.663 21.719 21.595 NCG 538 AL PASAR EL CURSOR rojo = obligatorio azul = ref. (satisface)



Jerarquía: Ley 21.663 Arts.7-9, Ley 21.719 Art.14 quin.-sex., Ley 21.595, NCG 538 (CMF). BOD 26-04 (CISA) es un estándar internacional de referencia voluntaria en Chile, no una ley. Línea **roja sólida** = la ley **exige** (obligatorio) el estándar; línea **azul punteada** = el estándar **satisface**/sirve de referencia para esa ley; línea **gris punteada** = control **transversal** requerido por 2+ estándares. Diagrama interactivo: pasa el cursor sobre un nodo o una línea para explorar sus conexiones; arrastra los nodos para reposicionarlos.

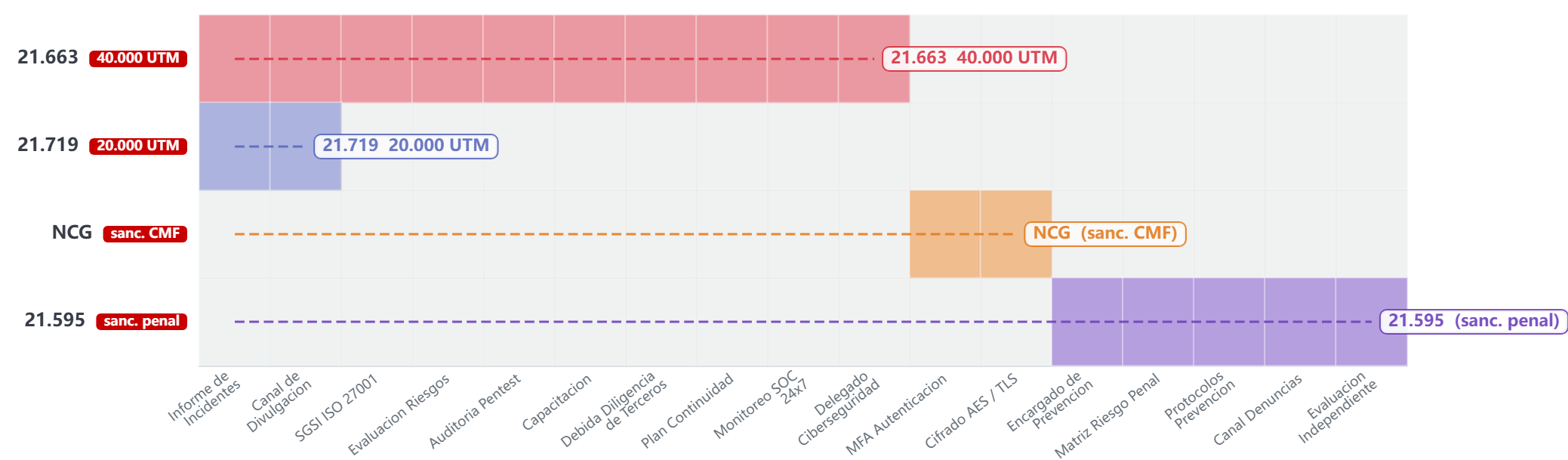
ROI en el cumplimiento: Matriz de Cobertura Legal por Control

Celda color = **control requerido** por esa ley (se rellena al implementarlo)

Celda gris = control **no requerido** por la ley

--

Línea punteada = **hito de multa** (techo verificable por ley)



Matriz derivada de **STD_DEFS** (misma fuente que el mapa de convergencia): cada fila es una ley y las celdas de color son los controles que esa ley exige vía sus estándares. Las columnas siguen el orden de implementación de **máxima cobertura primero** (Informe de Incidentes y Canal de Divulgación cubren 2 leyes; el resto, 1). La línea punteada de cada ley marca el **hito de multa**: el rango de controles que hay que implementar para cubrirla y su techo verificable — 21.719 = 20.000 UTM al completar (paso 2), 21.663 = 40.000 UTM (paso 10, ISO + Informe). 21.595 y NCG 538 no definen multa en UTM, pero **sí tienen sanción**: la 21.595 es una ley penal (presidio e inhabilidades para directores/ejecutivos, según el Código Penal y la propia ley) y el incumplimiento de la NCG 538 habilita a la CMF a aplicar multas administrativas e inhabilidades (régimen sancionatorio de la Ley General de Bancos / mercado de valores). Por eso se registran con su tipo de sanción y no con un monto UTM. Techos legales verificables: Ley 21.663 Art.40 = 40.000 UTM para OIV (20.000 si es un Servicio Esencial); Ley 21.719 = 20.000 UTM. Son **techos máximos de sanción** (criterios de graduación: reincidencia, gravedad, capacidad económica, cooperación), no una multa que se activa automáticamente por carecer de controles; la sanción concreta la determina la autoridad caso a caso. UTM=\$69.611 CLP (Feb 2026): 40.000 UTM ≈ \$2.800M CLP; 20.000 UTM ≈ \$1.400M CLP.

Lista de verificación de convergencia: Ley → Estándar → Control

Jerarquía de 3 capas, Igual que el diagrama y el informe PDF: cada **ley** (cuadro de color) exige sus **estándares** (nivel intermedio), y cada estándar se completa implementando **todos** sus **controles** (nivel inferior). Los controles transversales aparecen en cada estándar que los requiere.

21.663

Ley 21.663 Ciberseguridad

ISO 27001 (SGSI)

EXIGIDO

SGSI ISO 27001

Evaluacion Riesgos

Auditoria Pentest

Capacitacion

Debida Diligencia de Terceros

Plan Continuidad

Monitoreo SOC 24x7

Delegado Ciberseguridad

BOD 26-04 (Gest. Vulnerabilidades)

SATISFACE

Informe de Incidentes

Auditoria Pentest

Canal de Divulgacion

Informe y Notificacion

EXIGIDO

Informe de Incidentes

Canal de Divulgacion

21.719

Ley 21.719 Datos Personales

ISO 27001 (SGSI)

SATISFACE

SGSI ISO 27001

Evaluacion Riesgos

Auditoria Pentest

Capacitacion

Debida Diligencia de Terceros

Plan Continuidad

Monitoreo SOC 24x7

Delegado Ciberseguridad

NCG 538 (Regulacion CMF)

SATISFACE

MFA Autenticacion

Cifrado AES / TLS

Informe y Notificacion

EXIGIDO

Informe de Incidentes

Canal de Divulgacion

21.595

Ley 21.595 Delitos Economicos

Modelo de Prevencion de Delitos (Ley 20.393)

EXIGIDO

Encargado de Prevencion

Matriz Riesgo Penal

Protocolos Prevencion

Canal Denuncias

Evaluacion Independiente

NCG

NCG 538 CMF

NCG 538 (Regulacion CMF)

EXIGIDO

MFA Autenticacion

Cifrado AES / TLS

Recomendaciones para Directores y Responsables de Seguridad de la Información (CISOs)

1 SGSI ISO 27001: el control de mayor apalancamiento regulatorio

Un Sistema de Gestión de Seguridad de la Información certificado bajo ISO 27001 satisface simultáneamente **10 requisitos de 3 marcos legales** (Ley 21.663 Arts.8(a)-(f), Ley 21.719 Art.14 quin., Ley 21.595) y se alinea con la referencia internacional **BOD 26-04** (CISA, voluntaria en Chile). Según G-CERTI (2026) el ROI promedio de certificación es de **8.3 meses** y reduce el impacto de brecha en **62%** (de USD 4.2M a USD 1.6M promedio LATAM). El costo de implementación (\$17-79M CLP año 1 según FideliNorm 2026) representa entre 0.6% y 2.8% del techo de sanción gravísima para un OIV (40.000 UTM ≈ \$2.800M CLP). **Una sola sanción del techo paga 35 veces la inversión.** El 62% GER (TTPSEC Q1 2026) indica que 2 de cada 3 controles existen solo en papel. La prioridad debe ser operacionalizar, no documentar.

2 Convergencia de informes: un mismo flujo para 3 autoridades

Un único proceso de detección y escalamiento de incidentes satisface los plazos de **Ley 21.663 Art.9** (alerta temprana 3h, informe 72h, final 15d) y **Ley 21.719 Art.14 sexies** (notificación a APDP sin dilaciones indebidas), y se alinea con la referencia **BOD 26-04 CISA** (informe de vulnerabilidades explotadas). IBM: Costo de una Brecha de Datos 2025 documenta que organizaciones con detección y contención en menos de 200 días reducen el costo de brecha de USD 3.12M a USD 2.40M. El 68% de organizaciones LATAM sufrió al menos un incidente en 2025 (G-CERTI). **Diseñar un flujo único de informe reduce el riesgo de omisión y duplica la capacidad de respuesta sin duplicar recursos.** La relación asimetría es estructural: por cada USD 1 invertido en ciberseguridad en LATAM, el costo esperado de brecha es USD 49 (TTPSEC/G-CERTI 2026).

3 Responsabilidad penal del directorio: el riesgo que no se transfiere

La **Ley 21.595 de Delitos Económicos** modificó el artículo 3 de la Ley 20.393, eliminando la exigencia de que el delito informático se cometa en "interés o provecho" de la organización. Hoy basta con que ocurra "en el marco de la actividad" de la empresa para que el directorio sea penalmente responsable. Esto se conoce como **estándar Caremark**: el directorio debe demostrar que implementó y supervisó activamente sistemas de información y control. Aguila & Cía. (2026) advierte que las resoluciones de ANCI que constatan infracciones constituyen prueba poderosa de culpa civil. **Documentar las decisiones de ciberseguridad (regla del juicio empresarial) es la única protección legal del directorio.** Implementar Delegado de Ciberseguridad (Ley 21.663 Art.8(i)), delegado de protección de datos (DPO, Ley 21.719) y un Modelo de Prevención de Delitos (Ley 21.595) mitiga este riesgo y satisface 3 leyes simultáneamente.

4 El cumplimiento obligatorio ya comenzó: primera multa ANCI y convergencia Dic-2026

La prensa especializada informó como primera sanción del nuevo régimen la **Resolución Exenta ANCI N°214 (Abr 2026)**: una multa de 5.000 UTM a una empresa de telecomunicaciones por no reportar un ataque de ransomware que mantuvo servicios críticos caídos por más de 72 horas (referencias de prensa en Diario Financiero, 16 Abr 2026, citadas por Aguila & Cía.). *Nota de rigor: la resolución no está publicada íntegramente en el sitio oficial de la ANCI al cierre de esta edición, por lo que el detalle proviene de fuente de prensa y debe verificarse antes de usarse como precedente formal.* El mismo informe indicó que la autoridad consideró que la empresa tenía un plan en papel pero no canales de escalamiento operativos — ausencia del **control de informe y notificación** (plazo de notificación del Art.9). **El 62% GER (TTPSEC) sugiere que esta situación se replica en la mayoría de los OIV.** A esto se suma la **Ley 21.719** con vigencia plena el **1 de diciembre de 2026**, que creará la Agencia de Protección de Datos con facultades sancionatorias independientes (multas de hasta 20.000 UTM). Un mismo incidente puede generar sanciones paralelas de ANCI y APDP, además de responsabilidad civil y penal. La ventana para implementar controles convergentes se cierra en **5 meses**.

Fuentes y metodología

- **Ley N° 21.663** — Marco de Ciberseguridad (Chile, 2024). Crea ANCI, define obligaciones OIV (Arts.7-9), régimen sancionatorio (Art.40). bcn.cl/leychile/1202434
- **Ley N° 21.719** — Protección de Datos Personales (Chile, 2024). Vigencia 1-Dic-2026. Deberes de seguridad (Art.14 quin.), notificación de brechas (Art.14 sexies). bcn.cl/leychile/1209272
- **Ley N° 21.595** — Delitos Económicos. Modifica Ley 20.393, responsabilidad penal de directores por delitos informáticos. bcn.cl/leychile/1195119
- **NCG N° 538** — Comisión para el Mercado Financiero (CMF). Autenticación multifactor (MFA) para operaciones financieras en Chile. 2026.
- **Instrucciones Generales ANCI N°1-4** — Registro en plataforma, delegado de ciberseguridad (IG N°3), gestión de incidentes (IG N°4). 2025-2026.
- **Resolución Exenta ANCI N° 214** (Abr 2026) — Reportada por prensa como primera multa del régimen: 5.000 UTM a telecom por no informar ransomware (ausencia del control de informe del Art.9). No publicada íntegramente; referencias en Diario Financiero, 16 Abr 2026 (citado por Aguila & Cía.). Verificar en Diario Oficial.

- **BOD 26-04** — CISA Binding Operational Directive. Reemplaza CVSS por priorización dinámica basada en exposición, KEV, automatización del ataque e impacto. Junio 2026. cisa.gov
- **NCh-ISO 27001:2022** — Sistemas de Gestión de Seguridad de la Información. Adoptada como referencia por ANCI (Art.28 Ley 21.663).
- **RFC 9116** — IETF. Formato security.txt para divulgación coordinada de vulnerabilidades. rfc-editor.org/rfc9116

- **FideliNorm** (2026) — Cuánto cuesta implementar ISO 27001 en Chile. Rangos por tamaño de empresa: \$17-79M CLP año 1. fidelinorm.com
- **Confiden360** (2026) — Costos de certificación ISO 27001 en Chile. Desglose por componente. confiden360.com
- **GRC360** (2026) — Costos certificación ISO 27001: presupuesto real mercado chileno. grc360.cl
- **G-CERTI** (2026) — Informe Ciberseguridad Regional 2026. 890 organizaciones, 15 países. ROI de ISO 27001: 8.3 meses. Reducción de impacto: 62%. gcerti.org

- **IBM Security** (2025) — Costo de una brecha de datos: informe global. Costo global: USD 4.44M. LATAM: USD 2.51M. ibm.com/reports/data-breach
- **TTPSEC / Vargas, S.** (Q1 2026) — Radiografía del mercado chileno de ciberseguridad. GER: 62%. Relación inversión:brecha 1:49. 63.500 especialistas faltantes. blog.ttpsec.cl
- **Aguila & Cía.** (Jun 2026) — Impacto de Ley 21.663 en empresas: responsabilidad de directores, estándar Caremark, primera multa ANCI. aguilaycia.cl

- **anci-oiv-resolver** v0.6.0 — Mellafe Z., D. Resolver canónico RUT a dominio para 915 OIVs chilenos. Apache 2.0. github.com/raceksd-source/anci-oiv-resolver
- **arXiv:2606.05594** — Mellafe Z., D. "The Coverage Gap: Chile's Cyber Disclosure Framework versus the USA, EU and UK". Jun 2026. arxiv.org/abs/2606.05594
- **Resolución Exenta ANCI N° 87** (Dic 2025) — Nómina definitiva 915 OIVs Etapa 1. DO 17-Dic-2025.
- **Resolución Exenta ANCI N° 187** (Jul 2026) — Nómina definitiva 239 OIVs Etapa 2. Censo propio sobre 917 dominios, 28-Jul-2026.

HF-RPT-2026-003 v3.0 — Investigación Hackfluency — hackfluency.com

.Fuentes: Ley 21.663 · Ley 21.719 · Ley 21.595 · NCG 538 (CMF) · BOD 26-04 (CISA) · IBM: Costo de una Brecha de Datos 2025 · G-CERTI 2026 · FideliNorm 2026 · Confiden360 2026 · TTPSEC Q1 2026 · Aguila & Cía. 2026 · anci-oiv-resolver v0.6.0 · arXiv:2606.05594

© 2026 Hackfluency. Este documento es una herramienta de visualización de convergencia regulatoria. No constituye asesoría legal. Última actualización: Julio 2026.

HACKFLUENCY · CHILE 2026

¿Quieres cerrar la brecha con un plan accionable?

Agenda una conversación de 30 minutos con nuestro equipo de investigación y convierte este mapa en una hoja de ruta priorizada para tu organización.

Iniciar conversación →

← hackfluency.com